Smart-Q Security Test & Validation Report

Test ID	Security Test Case	Attack Scenario / Input	Protection Implemented	Expected Result	Actual Result	Status
SEC-01	Input Validation	Invalid email, weak password, empty fields	validator.js validation rules	Invalid input rejected before DB operation	Invalid requests rejected with 400 response	PASS
SEC-02	Cross-Site Scripting (XSS)	<script>alert(1)</script> injected in input fields	sanitize-html input sanitization	Script tags removed before storage	HTML tags stripped and sanitized	PASS
SEC-03	NoSQL Injection	{ "$gt": "" }, email[$ne]=null	express-mongo-sanitize middleware	Mongo operators removed from request	Query sanitized before DB execution	PASS
SEC-04	Brute Force Login	Multiple repeated login attempts	express-rate-limit	Excess requests blocked	Requests blocked after limit	PASS
SEC-05	JWT Authentication Validation	Invalid or expired token	jsonwebtoken verification in auth middleware	Unauthorized request rejected	401 response returned	PASS
SEC-06	Role-Based Access Control	Normal user accessing admin route	roleMiddleware("admin")	Access denied	403 Forbidden returned	PASS
SEC-07	Secure HTTP Headers	Browser security header verification	helmet middleware	Security headers attached	Headers present in response	PASS
SEC-08	HTTP Parameter Pollution	?role=user&role=admin	hpp middleware	Duplicate parameters filtered	Only single parameter processed	PASS

Test ID	Security Test Case	Attack Scenario / Input	Protection Implemented	Expected Result	Actual Result	Status
SEC-09	Large Payload / DoS	Very large JSON body	Express body parser limit (10kb)	Request rejected	Large request blocked	PASS
SEC-10	Sensitive Error Leakage	Trigger backend error	Global error handler	Stack traces hidden	Generic error message returned	PASS
SEC-11	Account Status Validation	Login attempt from inactive user	isActive check in auth middleware	Access denied	Login blocked	PASS
SEC-12	Authentication Header Validation	Missing or malformed Authorization header	Auth middleware validation	Unauthorized access rejected	401 Unauthorized returned	PASS

Security Middleware Used

Security Layer	Technology Used	Purpose
HTTP Header Security	helmet	Prevents clickjacking, MIME sniffing, etc
Rate Limiting	express-rate-limit	Protects against brute force attacks
Input Validation	validator.js	Validates email, phone, password
XSS Protection	sanitize-html	Removes malicious scripts
NoSQL Injection Protection	express-mongo-sanitize	Prevents MongoDB operator injection
Parameter Pollution	hpp	Prevents duplicate query attacks
Authentication	jsonwebtoken	Secure user authentication
Authorization	roleMiddleware	Restricts admin routes
Error Handling	Global error handler	Prevents information leakage

---

Security Weaknesses Identified (Minor)

Issue ID	Description	Risk Level	Recommendation
ISS-01	Weak password rule (min length 6)	Medium	Increase to 8+ with symbols
ISS-02	Test email endpoint exposed	Low	Disable in production
ISS-03	No refresh token system	Medium	Implement refresh tokens
ISS-04	No account lock after failed logins	Medium	Lock after 5 attempts
ISS-05	No security logging	Low	Add logging with winston

Final Security Evaluation

Category	Score
Input Security	9 / 10
Authentication	9 / 10
Authorization	9 / 10
API Hardening	8 / 10
Error Handling	8 / 10

Overall Security Rating
8.7 / 10

Conclusion

The Smart-Q backend implements a layered security architecture protecting against major web vulnerabilities such as XSS, NoSQL injection, brute-force attacks, and unauthorized access. Security middleware including Helmet, rate limiting, sanitization, and role-based access control ensures that requests are validated and authenticated before reaching business logic. The system successfully mitigates common OWASP threats while maintaining stable and secure API behavior.